

# Phishing : repérer un e-mail piégé

Le phishing (ou hameçonnage) est un e-mail qui se fait passer pour un expéditeur de confiance afin de vous faire cliquer sur un lien, ouvrir une pièce jointe ou donner vos identifiants. Les pirates imitent de mieux en mieux les messages officiels, et ils utilisent parfois un compte @eduvaud.ch qu'ils ont déjà volé. Personne n'est à l'abri : c'est pour cela qu'il faut prendre l'habitude de vérifier.

Avant de faire confiance à un e-mail, passez-le au crible de ces quatre vérifications :

1. **Le message** : que me demande-t-on, et sur quel ton ?
2. **L'expéditeur** : qui a vraiment envoyé ce message ?
3. **Les liens** : où m'emmènent-ils réellement ?
4. **Les pièces jointes** : puis-je les ouvrir sans risque ?

## 1. Le message

Lisez le message comme un détective. Plusieurs signaux doivent vous alerter :

- **L'urgence ou la menace** : « Votre compte sera supprimé dans 24 h », « Dernier avertissement ».
- **Une demande d'informations personnelles** : mot de passe, code reçu par SMS, numéro de carte. Aucun service du gymnase ni de la DGEP ne vous demandera votre mot de passe par e-mail.
- **Une offre trop belle** : carte cadeau, gain à un concours auquel vous n'avez pas participé.
- **Une formulation étrange** : fautes, traduction automatique, salutation impersonnelle (« Cher utilisateur »).
- **Un message inattendu** : un document « partagé » par quelqu'un qui ne vous envoie jamais rien.

**Le bon réflexe** : si le message vous presse d'agir, prenez justement le temps de vérifier. L'urgence est l'arme principale des pirates.

## 2. L'expéditeur

Le nom affiché (« Secrétariat », « Service informatique ») peut être choisi librement par n'importe qui. Ce qui compte, c'est l'adresse complète, et surtout ce qui se trouve après le @. Pour vos échanges scolaires, le domaine attendu est @eduvaud.ch.

**Le bon réflexe** : cliquez sur le nom de l'expéditeur (ou survolez-le avec la souris) pour afficher son adresse complète.

| Exemple d'expéditeur                                                    | Verdict | Pourquoi ?                                                                                                  |
|-------------------------------------------------------------------------|---------|-------------------------------------------------------------------------------------------------------------|
| Affiché : Secrétariat du gymnase<br>secreteriat.gdb@gmail.com           | Suspect | Une messagerie gratuite (Gmail, Outlook.com...) n'est pas une adresse officielle de l'école.                |
| Affiché : Support informatique DGEP<br>support@eduvaud-securite.com     | Suspect | Le domaine ressemble à eduvaud.ch mais c'est un autre domaine : eduvaud-securite.com.                       |
| Affiché : Microsoft 365 Eduvaud<br>no-reply@eduvaud.ch.verif-compte.net | Suspect | Le vrai domaine est ce qui termine l'adresse : verif-compte.net. Le « eduvaud.ch » au milieu est un leurre. |

| Exemple d'expéditeur                              | Verdict | Pourquoi ?                                                                                                                                       |
|---------------------------------------------------|---------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Affiché : Marie Dupont<br>marie.dupont@eduvaud.ch | Fiable  | Domaine officiel @eduvaud.ch.<br>Attention : un compte eduvaud piraté peut aussi envoyer du phishing.<br>Vérifiez aussi le contenu et les liens. |

Si vous répondez à un message, vérifiez l'adresse qui apparaît dans le champ « À » : elle doit être la même que celle de l'expéditeur.

### 3. Les liens

Le texte d'un lien peut afficher une adresse, et mener vers une tout autre. Seule l'adresse réelle compte.

**Le bon réflexe** : survolez le lien sans cliquer (sur téléphone : appui long) et lisez l'adresse qui s'affiche.

#### Comment lire une adresse web

Repérez le premier « / » après « https:// ». Juste avant, lisez de droite à gauche : les deux derniers blocs forment le vrai domaine.

- <https://moodle.gymnasedebeaulieu.ch/course/...>  
→ domaine : **gymnasedebeaulieu.ch**
- <https://eduvaud.sharepoint.com/sites/...>  
→ domaine : **sharepoint.com**, espace eduvaud
- <https://moodle.gymnasedebeaulieu.ch.connexion-eleves.net/>  
→ domaine : **connexion-eleves.net** !

Les adresses de confiance pour vos cours sont donc **moodle.gymnasedebeaulieu.ch** et **eduvaud.sharepoint.com**.

| Lien affiché → lien réel                                                                                                                                                                                   | Verdict | Pourquoi ?                                                                                     |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|------------------------------------------------------------------------------------------------|
| Affiché :<br>moodle.gymnasedebeaulieu.ch/course/view.php?id=42<br>Réel : <a href="https://moodle.gymnasedebeaulieu.ch/course/view.php?id=42">https://moodle.gymnasedebeaulieu.ch/course/view.php?id=42</a> | Fiable  | L'adresse réelle correspond à l'adresse affichée, et c'est le Moodle du gymnase.               |
| Affiché : Ouvrir le document partagé<br>Réel : <a href="https://eduvaud.sharepoint.com/:w:/s/classe3M5/...">https://eduvaud.sharepoint.com/:w:/s/classe3M5/...</a>                                         | Fiable  | Le domaine est bien eduvaud.sharepoint.com, l'espace SharePoint du canton.                     |
| Affiché : eduvaud.sharepoint.com/document<br>Réel : <a href="https://eduvaud-sharepoint.com.login-verify.io/">https://eduvaud-sharepoint.com.login-verify.io/</a>                                          | Suspect | Le texte affiché est correct, mais le lien réel mène vers login-verify.io.                     |
| Affiché : Se connecter à Moodle<br>Réel : <a href="https://moodle-gymnasedebeaulieu.ch/login">https://moodle-gymnasedebeaulieu.ch/login</a>                                                                | Suspect | Un simple tiret a remplacé le point : moodle-gymnasedebeaulieu.ch est un autre domaine.        |
| Affiché : Vérifier mon compte<br>Réel : <a href="https://bit.ly/3xKq9Zp">https://bit.ly/3xKq9Zp</a>                                                                                                        | Suspect | Un lien raccourci cache la destination. Dans un e-mail « officiel », c'est un signal d'alarme. |

**Et le cadenas ?** Le cadenas dans la barre d'adresse signifie seulement que la connexion est chiffrée. Un site de phishing peut aussi en avoir un. Vérifiez toujours le domaine. Le plus sûr : taper vous-même moodle.gymnasedebeaulieu.ch ou passer par vos favoris plutôt que de cliquer sur un lien reçu.

## 4. Les pièces jointes

Une pièce jointe peut contenir un logiciel malveillant qui vole vos mots de passe ou chiffre vos fichiers. L'ouvrir peut suffire.

- N'ouvrez une pièce jointe que si l'expéditeur est fiable et que le message est cohérent.
- Méfiez-vous des fichiers .zip, .html, .exe, et des documents Office qui demandent d'« activer les macros ».
- Une facture ou un colis que vous n'attendiez pas ? Ne l'ouvrez pas.

**Le bon réflexe :** en cas de doute, demandez à l'expéditeur par un autre moyen (en personne, message Teams) s'il vous a bien envoyé ce fichier.

## En cas de doute

- Ne cliquez pas, ne répondez pas, n'ouvrez rien.
- Signalez le message à votre enseignant·e ou au support informatique du gymnase.
- Vous avez déjà cliqué ou saisi votre mot de passe ? Changez-le immédiatement et prévenez le support. Agir vite limite les dégâts, et il n'y a aucune honte à cela.

## À vous de jouer

Pour chaque situation, indiquez si le message est fiable ou suspect, et quel indice vous permet de le dire.

**Situation 1.** Un e-mail de « IT Eduvaud » <admin@eduvaud.ch-mail.com> vous informe que votre boîte est pleine et vous invite à cliquer sur « Augmenter mon espace ».

Fiable / Suspect – indice : .....

**Situation 2.** Votre enseignante, sophie.renaud@eduvaud.ch, vous rappelle le rendu de jeudi. Le lien « Déposer mon travail » pointe vers <https://moodle.gymnasedebeaulieu.ch/mod/assign/view.php?id=318>.

Fiable / Suspect – indice : .....

**Situation 3.** Un camarade vous écrit depuis son adresse @eduvaud.ch : « Regarde vite cette photo de toi 😊 » avec une pièce jointe photo.zip.

Fiable / Suspect – indice : .....

**Situation 4.** Un message annonce qu'un document a été partagé avec vous. Le lien affiché est « eduvaud.sharepoint.com », mais en le survolant vous voyez <https://eduvaud.sharepoint.com/docs-share.net/>.

Fiable / Suspect – indice : .....

### **Corrigé (pour l'enseignant·e)**

1. Suspect. Le domaine réel est ch-mail.com, pas eduvaud.ch, et le message joue sur l'urgence.
2. Fiable. Expéditeur @eduvaud.ch, message cohérent et attendu, lien vers le Moodle du gymnase.
3. Suspect. Le compte du camarade est peut-être piraté : ton inhabituel, curiosité provoquée et fichier .zip. Vérifier auprès de lui en personne.
4. Suspect. Le vrai domaine est docs-share.net ; « eduvaud.sharepoint.com » n'est qu'un préfixe trompeur.

Fiche inspirée de « Comment identifier un e-mail de phishing », Université de Genève (plone.unige.ch/distic). Adresses et liens d'exemple fictifs.